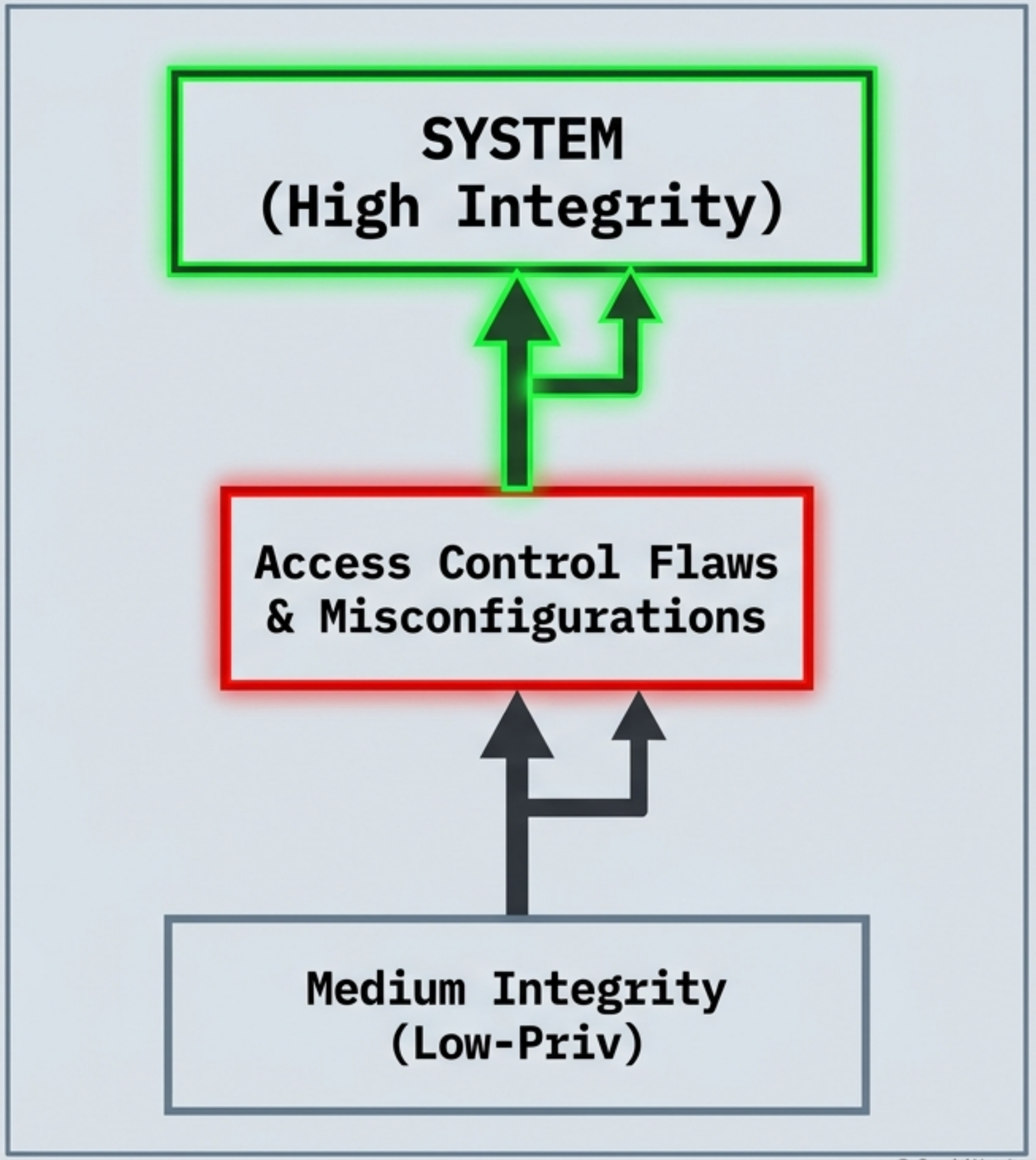
OSCP Windows Privilege Escalation: Tối ưu Tư duy từ Low-Priv đến SYSTEM

- **Mindset Shift:** Chuyển đổi tư duy từ thử sai công cụ sang phân tích hệ thống.
- **Bản chất PrivEsc:** Khai thác các Misconfigurations, Privileges (SeTokens), và Lỗ hổng ứng dụng.
- **Quy trình OSCP:** Cực hạn Enumeration -> Xác định Vector -> Leo thang quyền -> SYSTEM.
- **Nguyên tắc phòng thi:** Ưu tiên manual, tận dụng tối đa Living off the Land.

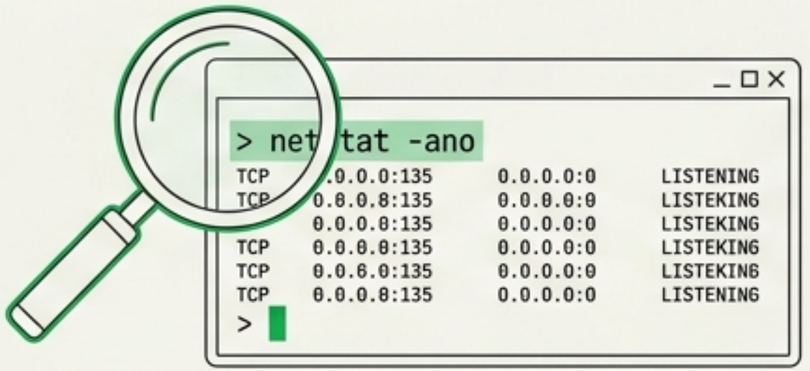


Gemini Notebook

Enumeration: Tầm quan trọng của Thủ công vs. Tự động

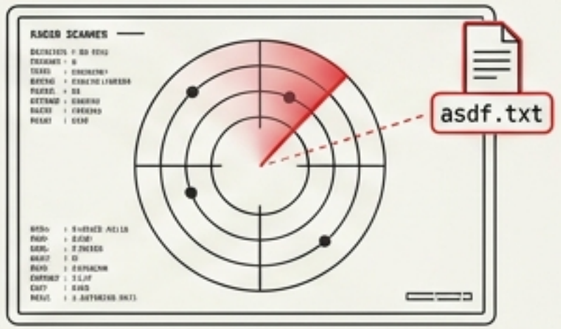
Manual Enumeration

- Dùng whoami /priv , netstat -ano , icacls (annext)
- Tàng hình, chính xác, hiểu sâu bối cảnh (Context)



Automated Tools (winPEAS)

- Quét diện rộng, tiết kiệm thời gian
- Tạo ra nhiều Noise và rác thông tin
- Điểm mù: winPEAS thường nhận diện sai OS hoặc bỏ sót file mật khẩu (VD: asdf.txt trên Desktop)



Chạy Manual Enumeration trước → Nắm bắt Situational Awareness → Chạy winPEAS ẩn nền để đối chiếu

Gemini Notebook

Kỹ thuật 1: Khai thác Unquoted Service Paths

Cơ chế

Lỗ hổng hàm **CreateProcess API** khi Path có khoảng trắng nhưng KHÔNG có dấu ngoặc kép.

Lỗi biên dịch

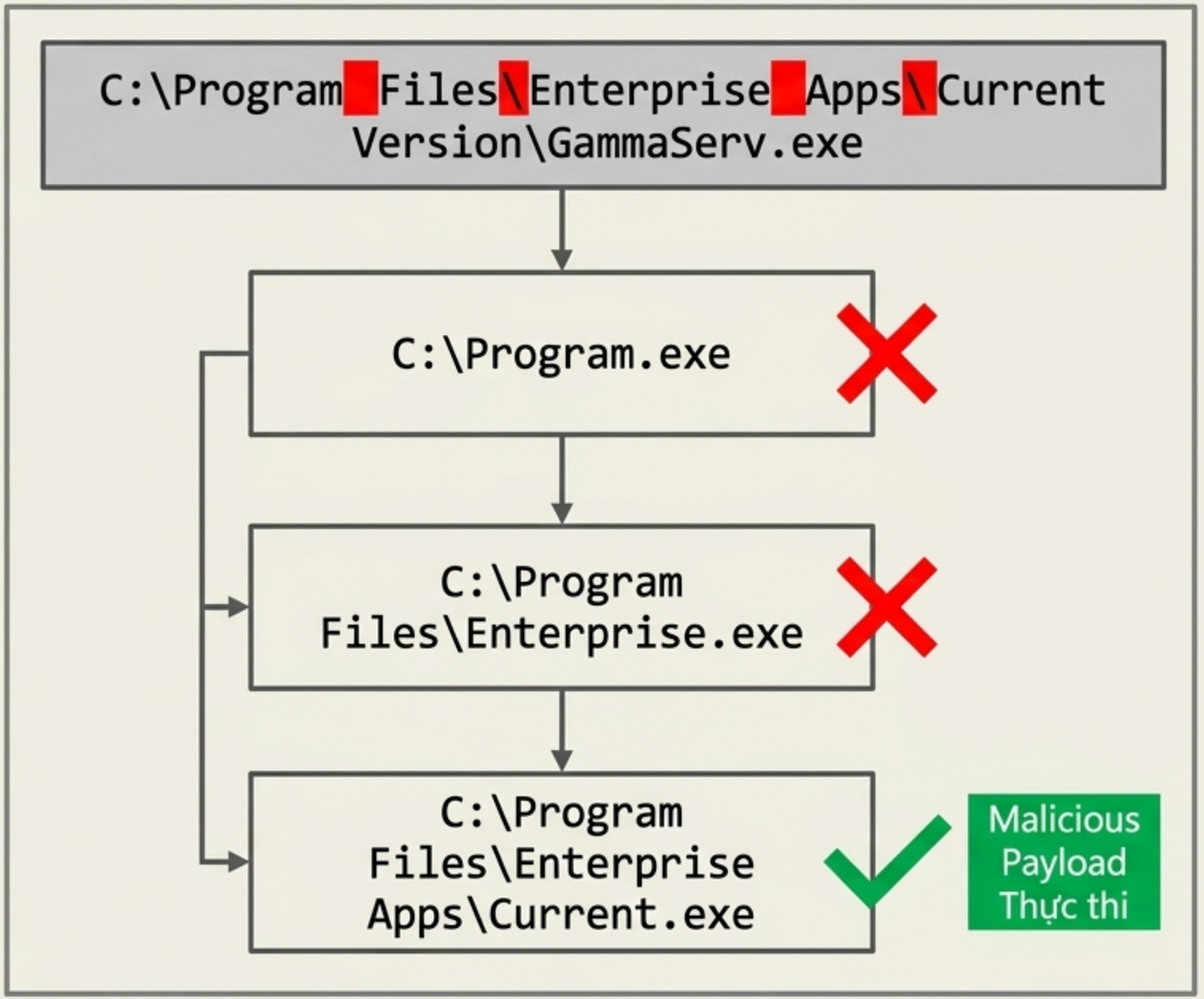
Windows cắt chuỗi tại mỗi khoảng trắng và nối đuôi .exe.

Tìm kiếm (WMIC)

```
wmic service get name,pathname
| findstr /i /v C:\Windows\
| findstr /i /v ""
```

Exploit

Drop Malicious Payload (VD: Current.exe) vào thư mục bị cắt có quyền Write -> Restart Service.



Gemini Notebook

Kỹ thuật 2: Insecure Service Permissions (Binary Hijacking)

1. Kiểm tra Quyền (Check Perms)

Misconfiguration cấp quyền Write/Modify cho User thường trên file thực thi.

```
icacls mysqld.exe
BUILTIN\Users:(F)
```

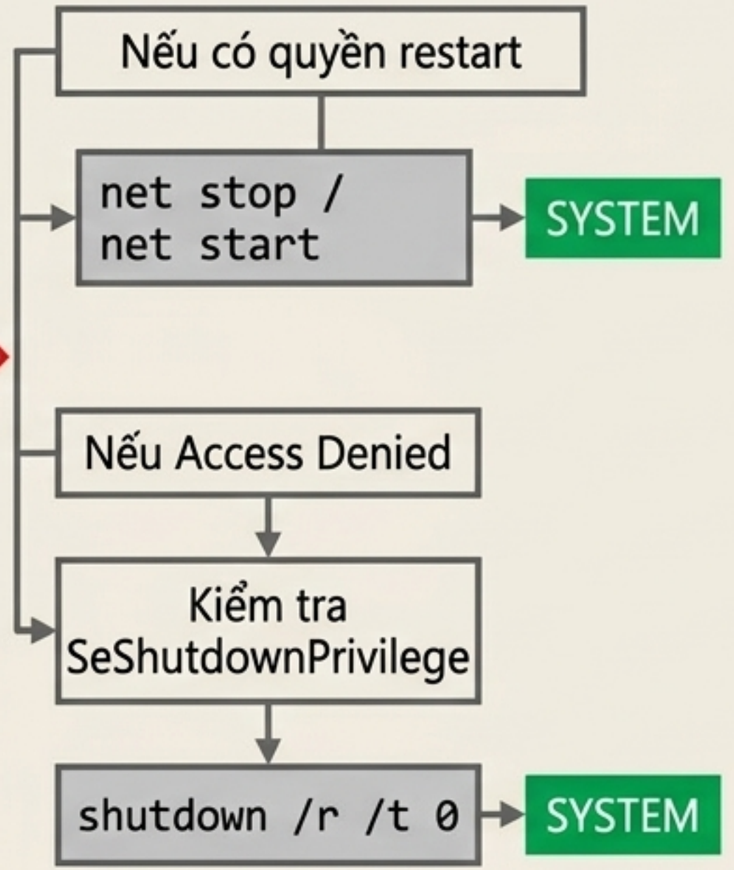
2. Thay thế Binary (Backup & Replace)

Backup file gốc và ghi đè bằng Malicious Binary.

```
move mysqld.exe
mysqld.bak
```



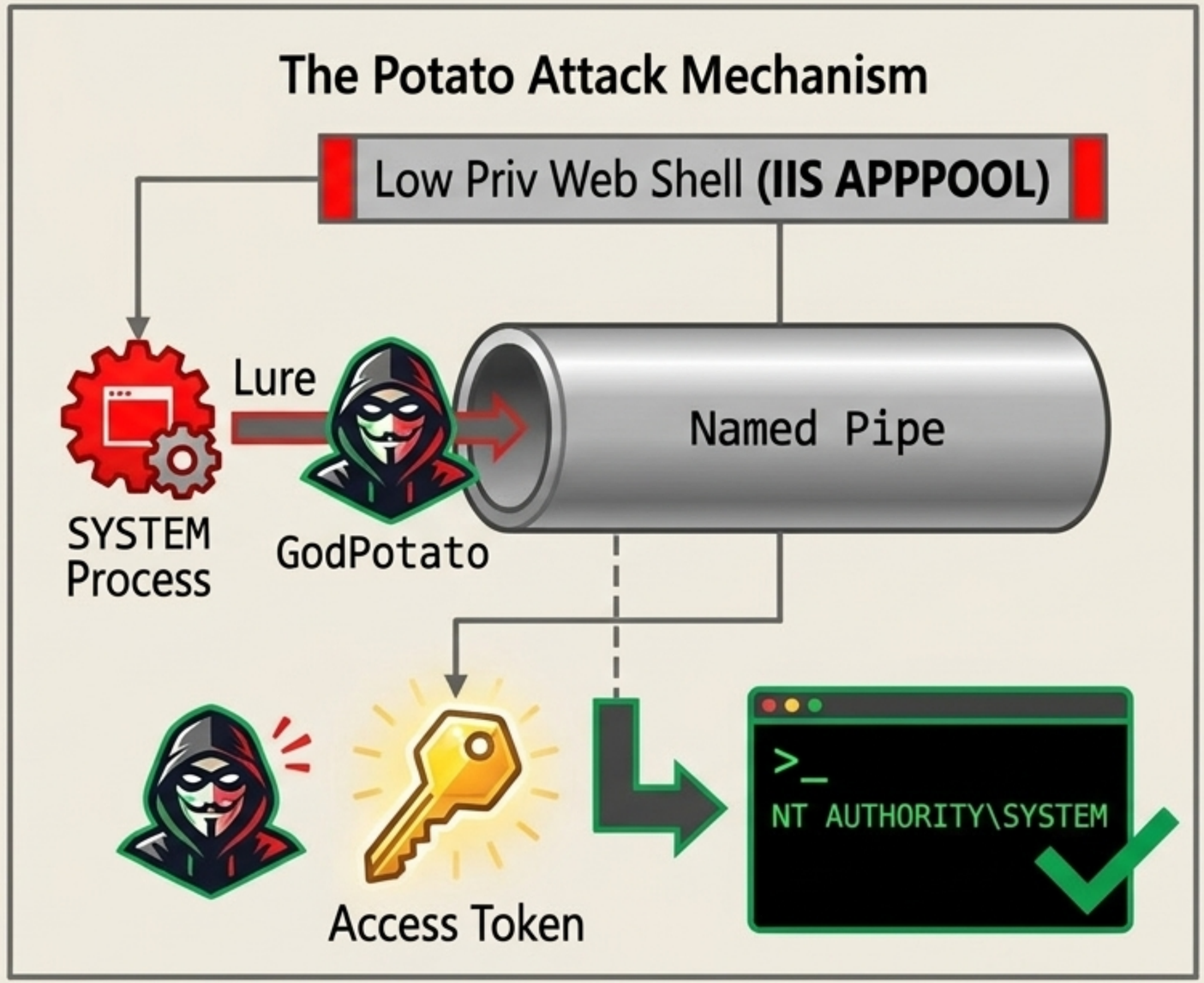
3. Kích hoạt (Trigger Execution)



Gemini Notebook

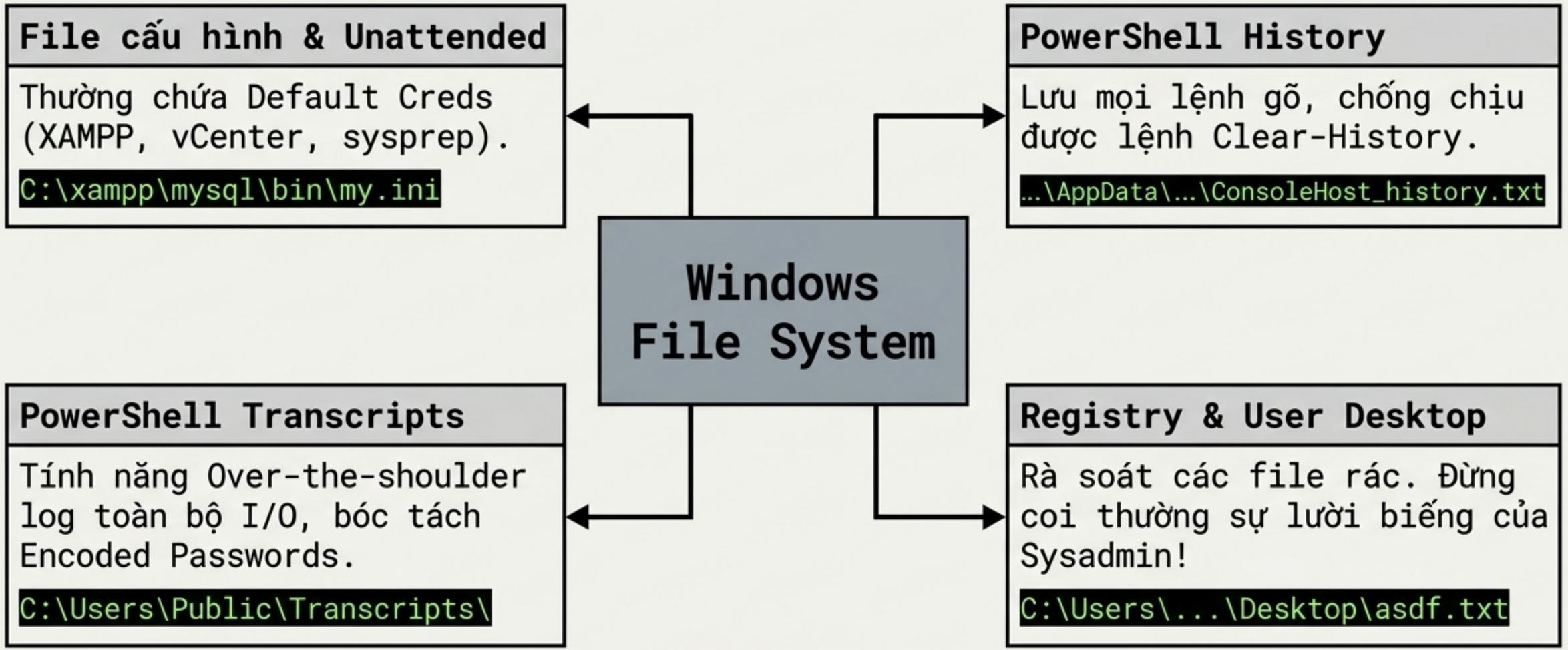
Kỹ thuật 3: Lạm dụng Token Privileges (SeImpersonate)

- **Mục tiêu:** Web Servers hoặc Services (IIS APPPOOL, LOCAL SERVICE) sở hữu `SeImpersonatePrivilege`.
- **Cơ chế hoạt động:** Ép một tiến trình đặc quyền (SYSTEM) xác thực qua một Named Pipe do kẻ tấn công kiểm soát.
- **Hành vi:** Đánh cắp Access Token của SYSTEM và mạo danh (Impersonate) bối cảnh bảo mật.
- **Vũ khí khuyên dùng:** Dòng họ Potato (SigmaPotato, GodPotato) - Thực thi lệnh mượt mà, đáng tin cậy.



Gemini Notebook

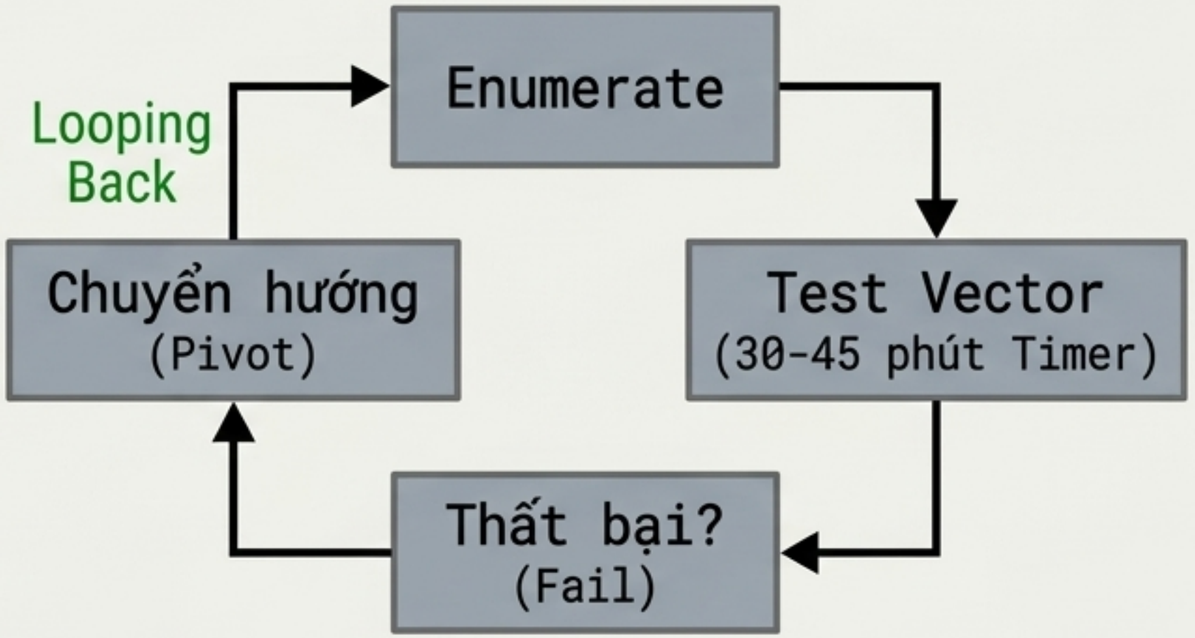
Rà quét Mật khẩu ẩn (Cleartext Credentials)



Gemini Notebook

OSCP Mindset: Chiến thuật tránh bẫy & Quản lý thời gian

- **Hiệu ứng Rabbit Holes:** Tránh sa đà vào giải mã file rác hoặc dịch vụ không thể leo quyền.
- **Quản lý thời gian (Timeboxing):** Hết giờ phải lập tức chuyển hướng (Pivot).
- **Tư duy Xoay vòng:** Có quyền User mới -> Khởi động lại quy trình Enumeration từ số 0.



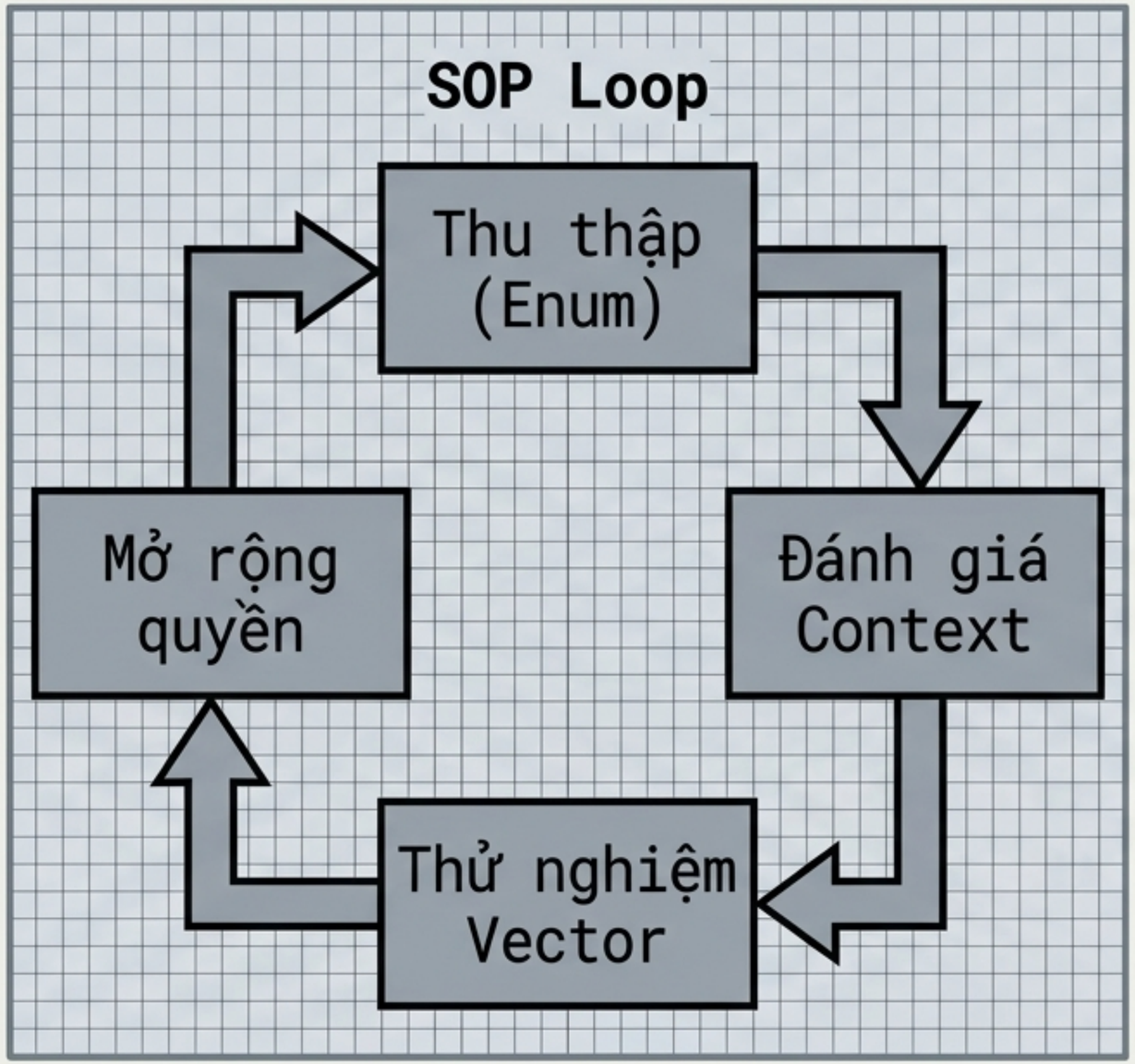


Vũ khí tối hậu: Kernel Exploits

Chỉ dùng khi đã cạn kiệt mọi hướng. Rủi ro làm Crash hệ thống (BSOD), gây mất điểm thi và tốn rất nhiều thời gian reset máy ảo trong môi trường OSCP.

Gemini Notebook

Tổng kết Quy trình & Tài nguyên Thực chiến



Tâm pháp PrivEsc

90% lỗi xuất phát từ phân quyền lỏng lẻo (Permissions) và quản lý Credential yếu kém. Giữ cái đầu lạnh, ghi chú tỉ mỉ, thử nghiệm có kiểm soát.

```
[+] Cheat Sheets & Vũ khí:
    - PayloadsAllTheThings
    - HackTricks (Đào sâu kỹ thuật)
```

```
[+] Khóa học & Luyện tập:
    - Tiberius Windows PrivEsc
    - Proving Grounds / HTB
```

Gemini Notebook